

SOFTWARE REQUIREMENTS SPECIFICATION SECURITY REQUIREMENTS DOCUMENT (SRS-Sec)

Sistem Booking Hotel

Secure Software Engineering · Teknik Informatika · Universitas Palangka Raya

1. Deskripsi Sistem

Hotel Booking Secure System adalah sistem pemesanan hotel berbasis web yang digunakan untuk membantu pengguna dalam melakukan registrasi akun, login, pencarian kamar, booking kamar, pembayaran, serta melihat riwayat pemesanan. Sistem ini dibangun menggunakan beberapa komponen teknologi, yaitu HTML, CSS, dan JavaScript pada bagian frontend yang berjalan di browser, PHP sebagai backend, MySQL sebagai database, serta payment gateway sebagai layanan eksternal untuk memproses pembayaran. Sistem ini memiliki beberapa pihak yang terlibat, yaitu Tamu/User sebagai pengguna akhir, Admin sebagai pengelola sistem, Payment Gateway sebagai pihak eksternal pemroses pembayaran, dan Developer sebagai tim yang bertanggung jawab dalam pengembangan, pengujian, serta pemeliharaan sistem.

Alur data pada sistem dimulai dari Tamu/User yang melakukan registrasi dengan mengirimkan data seperti nama, email, dan password. Sistem kemudian memvalidasi input, melakukan hashing password, menyimpan data pengguna ke database, lalu menampilkan status registrasi berhasil atau gagal. Setelah itu, pengguna dapat login menggunakan email dan password. Sistem akan memvalidasi kredensial melalui proses Login/Register, mencocokkan password dengan password hash pada database, lalu membuat session atau token autentikasi apabila data valid. Setelah berhasil login, pengguna dapat melakukan pencarian kamar dengan memasukkan tanggal menginap, tipe kamar, dan jumlah kamar. Sistem akan memvalidasi input pencarian, mengambil data ketersediaan kamar dan harga dari database, kemudian menampilkan hasil pencarian kamar yang tersedia.

Selanjutnya, pengguna dapat melakukan booking kamar dengan memilih kamar dan mengirimkan detail booking seperti tanggal, tipe kamar, jumlah tamu, serta metode pembayaran. Sistem akan memvalidasi data booking di sisi server, memeriksa ketersediaan kamar, menyimpan data booking ke database, lalu memberikan konfirmasi berupa ID booking. Pada proses pembayaran, sistem membuat permintaan transaksi ke payment gateway, kemudian payment gateway memproses pembayaran dan mengirimkan callback status pembayaran ke sistem. Sistem akan memverifikasi signature, timestamp, nominal pembayaran, dan ID booking sebelum memperbarui status transaksi pada database. Di sisi

admin, admin dapat login ke dashboard setelah sistem memvalidasi akun dan role admin. Admin dapat mengelola data kamar, mengelola data booking, melihat laporan transaksi, serta memantau log aktivitas sistem. Setiap aktivitas penting seperti login, booking, pembayaran, callback payment gateway, dan perubahan data akan dicatat ke audit log tanpa menyimpan data sensitif seperti password, token, API key, atau informasi kartu pembayaran.

2. Identifikasi Aset Kritis

Berdasarkan DFD dan komponen sistem, berikut aset kritis yang wajib dilindungi:

ID Aset	Nama Aset	Lokasi / Proses Terkait	Tingkat Risiko	Alasan Kritis
A-001	Kredensial login pengguna	P1.0 Login/Register, DS1 Db.Users	Kritis	Jika bocor, akun pengguna dapat diambil alih oleh pihak tidak sah.
A-002	Password hash	DS1 Db.Users	Kritis	Password harus disimpan dalam bentuk hash aman agar tidak terbaca langsung jika database bocor.
A-003	Data pribadi tamu	DS1 Db.Users	Kritis	Berisi informasi pengguna seperti nama, email, dan kontak yang bersifat sensitif.
A-004	Session token / cookie	Proses login dan manajemen sesi	Tinggi	Jika dicuri, penyerang dapat melakukan session

				hijacking dan masuk tanpa password.
A-005	Data booking	P2.0 Booking Kamar, DS2 Db.Booking	Tinggi	Manipulasi data booking dapat menyebabkan double booking, perubahan harga, atau status tidak valid.
A-006	Data transaksi pembayaran	P3.0 Pembayaran, DS3 Db.Transaksi	Kritis	Berkaitan langsung dengan pendapatan hotel dan validitas transaksi.
A-007	Status pembayaran	P3.0 Pembayaran, DS3 Db.Transaksi	Kritis	Status pembayaran yang dimanipulasi dapat menyebabkan booking dianggap lunas secara tidak sah.
A-008	Database sistem	DS1, DS2, DS3	Kritis	Menyimpan seluruh data penting sistem, termasuk user, booking, dan transaksi.

A-009	File konfigurasi	Backend server, .env, config.php	Kritis	Dapat berisi credential database, API key, dan secret payment gateway.
A-010	API key dan secret payment gateway	Environment variable, backend server	Kritis	Jika bocor, dapat digunakan untuk membuat transaksi palsu atau memalsukan callback.
A-011	Hak akses admin / RBAC	P1.0 Verify Role, P4.0 Manajemen Admin	Kritis	Bypass otorisasi dapat menyebabkan user biasa mengakses fitur admin.
A-012	Audit log	Log sistem, P4.0 laporan dan monitoring	Tinggi	Dibutuhkan untuk pelacakan insiden, pembuktian aktivitas, dan investigasi keamanan.
A-013	Source code aplikasi	Repository GitHub	Tinggi	Source code dapat mengandung celah keamanan atau konfigurasi sensitif jika

				tidak dikelola dengan benar.
A-014	Callback payment gateway	P3.0 Pembayaran ↔ Payment Gateway	Kritis	Callback palsu dapat mengubah status pembayaran tanpa transaksi valid.
A-015	Endpoint login, booking, dan pembayaran	Backend API	Tinggi	Target utama brute force, spam request, injection, dan manipulasi parameter.

3. Security Requirements

ID	Kategori	Prioritas	Security Requirement
SR-01	Autentikasi	HARUS	Sistem HARUS melakukan autentikasi pengguna menggunakan email/username dan password sebelum pengguna dapat mengakses fitur booking, pembayaran, atau panel admin.
SR-02	Autentikasi	HARUS	Sistem HARUS menyimpan password menggunakan

			algoritma hashing yang aman seperti bcrypt atau Argon2 , bukan dalam bentuk plaintext.
SR-03	Autentikasi	HARUS	Sistem HARUS menerapkan mekanisme session authentication dengan cookie yang memiliki atribut HttpOnly dan Secure .
SR-04	Autentikasi	SEBAIKNYA	Sistem SEBAIKNYA menerapkan pembatasan percobaan login seperti rate limiting dan temporary lockout setelah beberapa kali gagal login.
SR-05	Otorisasi	HARUS	Sistem HARUS menerapkan Role-Based Access Control (RBAC) untuk membedakan hak akses antara tamu/pengguna dan admin.
SR-06	Otorisasi	TIDAK BOLEH	Sistem TIDAK BOLEH

			mengizinkan pengguna mengakses, mengubah, atau menghapus data booking milik pengguna lain tanpa otorisasi yang valid.
SR-07	Input Validation	HARUS	Sistem HARUS memvalidasi seluruh input dari pengguna, termasuk data login, registrasi, pencarian kamar, detail booking, dan pembayaran di sisi server.
SR-08	Input Validation	HARUS	Sistem HARUS menggunakan prepared statement atau parameterized query untuk seluruh operasi database.
SR-09	Input Validation	TIDAK BOLEH	Sistem TIDAK BOLEH hanya mengandalkan validasi di sisi client/browser untuk data penting seperti nominal pembayaran, ID booking, role user, dan status transaksi.

SR-10	Data Protection	HARUS	Sistem HARUS menggunakan protokol HTTPS/TLS untuk seluruh komunikasi antara user, web client, backend, dan layanan eksternal.
SR-11	Data Protection	HARUS	Sistem HARUS menjaga kerahasiaan file konfigurasi seperti .env agar tidak dapat diakses publik atau ikut masuk ke repository.
SR-12	Data Protection	TIDAK BOLEH	Sistem TIDAK BOLEH menampilkan data sensitif seperti password, token, API key, credential database, atau informasi kartu pembayaran pada URL, log, maupun pesan error.
SR-13	Payment Security	HARUS	Sistem HARUS melakukan verifikasi signature atau checksum pada setiap callback dari payment gateway.

SR-14	Payment Security	HARUS	Sistem HARUS memvalidasi nominal pembayaran, ID booking, status transaksi, dan timestamp/nonce sebelum memperbarui status pembayaran.
SR-15	Payment Security	TIDAK BOLEH	Sistem TIDAK BOLEH memperbarui status pembayaran hanya berdasarkan request dari client tanpa validasi dari backend dan payment gateway.
SR-16	Audit & Logging	HARUS	Sistem HARUS mencatat aktivitas penting seperti login, logout, booking, perubahan data booking, pembayaran, callback payment gateway, dan aktivitas admin.
SR-17	Audit & Logging	HARUS	Sistem HARUS menyimpan log dengan timestamp, user ID, jenis

			aktivitas, alamat IP, dan status aksi berhasil/gagal.
SR-18	Audit & Logging	TIDAK BOLEH	Sistem TIDAK BOLEH menyimpan password, token session, API key, atau data pembayaran sensitif secara utuh di dalam log.
SR-19	Availability	HARUS	Sistem HARUS menerapkan rate limiting pada endpoint login, booking, dan pembayaran untuk mengurangi risiko flood request.
SR-20	Availability	SEBAIKNYA	Sistem SEBAIKNYA menerapkan throttling atau pembatasan request untuk mencegah spam booking request.
SR-21	Database Security	HARUS	Sistem HARUS membatasi akses database hanya dari backend/server yang

			sah, bukan langsung dari client/browser.
SR-22	Database Security	HARUS	Sistem HARUS menggunakan akun database dengan hak akses minimum sesuai kebutuhan aplikasi.
SR-23	Error Handling	HARUS	Sistem HARUS menampilkan pesan error yang umum kepada pengguna tanpa membocorkan detail teknis seperti query SQL, path server, atau stack trace.
SR-24	File & Configuration Security	TIDAK BOLEH	Sistem TIDAK BOLEH menyimpan API key payment gateway, database password, atau secret token langsung di source code.
SR-25	Admin Security	HARUS	Sistem HARUS membatasi fitur manajemen admin hanya untuk akun dengan role admin yang telah terverifikasi.

SR-26	Admin Security	SEBAIKNYA	Sistem SEBAIKNYA mencatat seluruh perubahan data yang dilakukan admin, termasuk perubahan booking, transaksi, data kamar, dan data pengguna.
--------------	----------------	-----------	---

4. Definisi Stakeholder & Trust Boundary

4.1 Stakeholder

No	Stakeholder	Peran	Kepentingan Keamanan
1	Tamu/User	Pengguna akhir yang melakukan booking hotel	Kerahasiaan data pribadi, keamanan akun, keamanan transaksi pembayaran, keakuratan status booking
2	Admin	Pengelola data hotel dan transaksi	Integritas data kamar, booking, transaksi, serta pembatasan akses sesuai role
3	Payment Gateway	Pihak ketiga yang memproses pembayaran	Validitas transaksi, keamanan callback, perlindungan dari transaksi palsu
4	Developer	Tim pengembang sistem	Keamanan kode, manajemen dependency, konfigurasi server, dan pencegahan kebocoran secret
5	Database Server	Komponen penyimpanan data	Menjaga kerahasiaan, integritas, dan ketersediaan data user, booking, dan transaksi
6	Pemilik Hotel / Manajemen	Pihak yang menggunakan data laporan untuk operasional	Keakuratan laporan transaksi, perlindungan data bisnis, dan keandalan sistem

4.2 Trust Boundary

Trust boundary adalah batas kepercayaan antara komponen sistem yang memiliki tingkat kepercayaan berbeda. Pada sistem ini, trust boundary terlihat pada perpindahan data dari browser user ke server, dari backend ke database, serta dari sistem internal ke payment gateway eksternal. Setiap perpindahan data melewati trust boundary harus dilindungi dengan mekanisme keamanan yang sesuai.

Boundary ID	Antara Zona / Komponen	Risiko Utama	Mekanisme Keamanan
TB-01	User Browser ↔ Web Client	Penyadapan data, input berbahaya, manipulasi request	HTTPS/TLS, input validation, anti-XSS, rate limiting
TB-02	Web Client ↔ PHP Backend	Manipulasi parameter, bypass validasi client	Server-side validation, CSRF protection, session authentication
TB-03	Backend ↔ Proses Login/Register P1.0	Brute force, credential stuffing, spoofing	Password hashing, rate limiting, lockout, generic error message
TB-04	P1.0 Login/Register ↔ DS1 Db.Users	SQL Injection, kebocoran kredensial	Prepared statement, bcrypt/Argon2, akses database terbatas
TB-05	User ↔ P2.0 Booking Kamar	Manipulasi tanggal, ID kamar, harga, status booking	Validasi server-side, cek ketersediaan kamar, anti-tampering
TB-06	P2.0 Booking Kamar ↔ DS2 Db.Booking	Double booking, perubahan status tidak sah	Transaction control, prepared statement, validasi status booking
TB-07	User ↔ P3.0 Pembayaran	Manipulasi nominal pembayaran, request palsu	Server-side validation, redirect payment gateway, tidak menyimpan data kartu

TB-08	P3.0 Pembayaran ↔ Payment Gateway	Fake callback, replay attack, manipulasi status pembayaran	Signature verification, timestamp, nonce, whitelist IP
TB-09	P3.0 Pembayaran ↔ DS3 Db.Transaksi	Perubahan status transaksi tidak sah	Validasi callback, audit log, prepared statement
TB-10	Admin ↔ P4.0 Manajemen Admin	Bypass admin panel, privilege escalation	RBAC, session validation, audit trail
TB-11	P4.0 Manajemen Admin ↔ Database Booking/Transaksi	Manipulasi data oleh admin atau akun admin yang disalahgunakan	RBAC, validasi input, logging perubahan data
TB-12	Backend Server ↔ File Konfigurasi	Kebocoran .env, API key, database password	Environment variable, file permission, .gitignore, blok akses publik
TB-13	Semua Proses ↔ Log Sistem	Kebocoran data sensitif melalui log	Masking data, logging tanpa password/token/API key